SecureWealth Twin

Wealth First, Security Always

One decision path for wealth advice and fraud defence — both explainable to the customer, in three languages, on the bank's own infrastructure.

Punjab & Sind Bank Hackathon Series 2026 · Supporting material for Q&A

WHAT IS ACTUALLY NEW

Three things you will not see elsewhere

1

Advice that is allowed to say no

When a customer has no investable surplus, the engine suppresses product advice entirely and tells them to fix expenses first. A wealth engine that cannot decline is a sales funnel.

2

An audit trail that survives its own bank

Four replicas, a hash chain, and an Ed25519 signature per record. Conflicts are settled by signature authority, not majority vote — so an insider who rewrites three of four copies still loses.

3

Novelty detection, not just rules

A PyTorch autoencoder trained only on legitimate behaviour flags patterns no rule anticipated. When it is unsure, the pipeline challenges — never a silent allow.

All three are demonstrated live — none of them are slideware.

DECISION LOGIC

How an investment is judged

Behaviour
8 boolean signals

›

Fraud ML
XGBoost, 22 features

›

Zero-day
Autoencoder

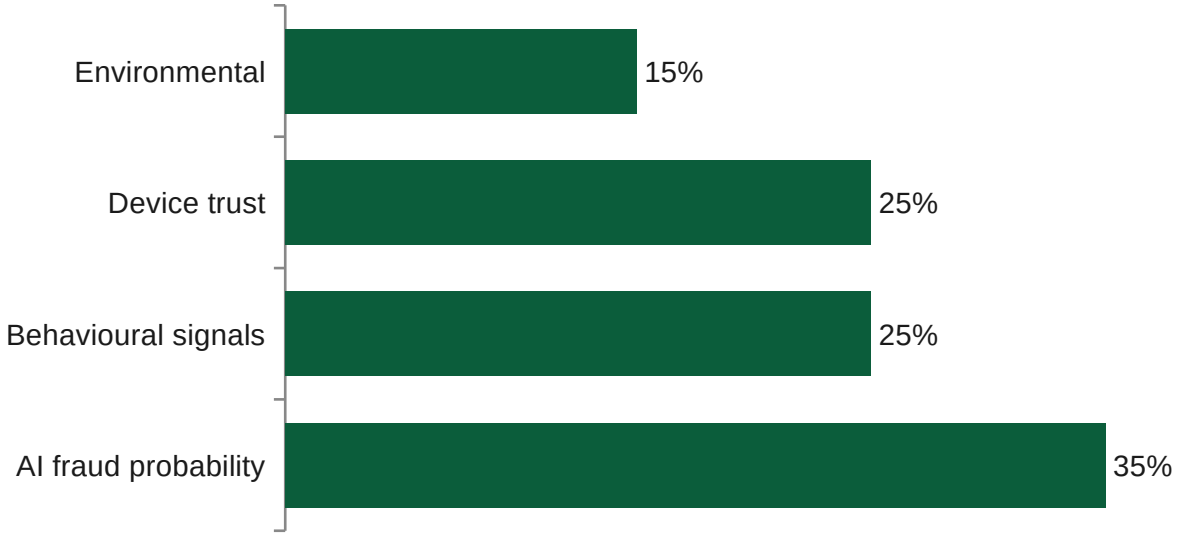
›

Risk
Weighted 0–100

›

Decision
4 bands

Risk score composition



Score decides the outcome

ALLOW	0 – 30	Goes through. No friction.
WARN	31 – 55	Proceeds with an advisory.
CHALLENGE	56 – 79	Step-up before money moves.
BLOCK	80 – 100	Stopped and reported.

Weights sum to 1.0 and that is asserted at import — the app refuses to start otherwise.

BE SPECIFIC

The behavioural signals, and what fires them

Signal	Penalty	Trigger condition	Basis
`extreme_amount_spike`	80	Greater than 10× the customer's own 90-day median	Outlier policy
`otp_distress`	60	OTP entered in under 2.5 seconds — bot or coercion	NIST SP 800-63B
`velocity_burst`	50	Three or more transactions inside five minutes	RBI velocity ceiling
`round_number_anomaly`	45	Round-amount share above 35% (baseline 15%)	Benford / FATF R.16
`amount_spike`	40	Above mean + 3σ, or more than 3× the 90-day median	Per-customer z-score
`otp_relay`	40	OTP entered after more than 60 seconds — relay attack	NIST SP 800-63B
`night_owl`	25	Between 23:01 and 05:59 IST	RBI 2025-26/219
`new_recipient`	20	Fund not seen before in this customer's history	First-party history

There is no fixed rupee limit anywhere in the system. Every threshold is derived from the individual customer's own history — which is why ₹95,000 is challenged for one customer and ₹90,000 passes for another.

WEALTH LOGIC

One engine, five different answers

0	Surplus at or near zero	**Suppress all product advice**	**Vishwas**
1	Runway under 4 months	**Emergency fund before anything else**	**Mahak**
2	Debt-to-income above 0.50	**Clear the costliest loan first**	**Archit**
3	Idle cash far above the buffer	**Deploy to deposit; flag maturing FDs**	**Ayush**
4	Buffer covered, debt healthy	**Growth via SIP**	**Swayam**

The engine stops at the first branch that applies, which is why each customer gets exactly one primary recommendation. Only mutual funds and deposits are ever recommended — no stocks, enforced in code.

INSIDER RESISTANCE

Why majority voting is the wrong answer

The attack

- Someone with database access rewrites a payment record — and updates three of the four replicas to match.
- Any system that resolves conflicts by majority now accepts the forgery: three copies agree.
- This is the realistic insider threat. It is not solved by more replicas.

Our answer

- Every record carries an Ed25519 signature over its content and its place in the hash chain.
- Verification trusts the signature, not the count. Forged copies fail signature checks regardless of how many there are.
- One honest replica is enough to reconstruct the truth — and the system repairs itself from it.

10 red-team scenarios run live from the admin dashboard — including this one. All 10 defended, chain intact afterwards.

ENGINEERING POSTURE

Data protection, detection and scale

Customer data

The LLM runs locally on bank infrastructure — explanations never leave the network for a third-party AI provider. TLS in transit, encryption at rest, MPINs hashed and never logged.

Unauthorised access

Token sessions, per-device registration with a trust state, consent-gated aggregation APIs that return 403 without consent, and a separate key for admin endpoints.

Detection timing

In-line, before money moves — not batch reconciliation. The full pipeline returns a verdict on every investment, with model inference in single-digit milliseconds.

Scale

Stateless API scales horizontally behind a standard load balancer; session state lives in the token. Models are small enough to sit in-process, so there is no separate inference tier.

FastAPI · SQLAlchemy · PostgreSQL · React Native · XGBoost · PyTorch · Ed25519 · local LLM

WHAT WE DID NOT BUILD

Honest gaps, and where they plug in

Conversational & voice assistant

Not built. The substrate is: seven explainability engines already answer “why was I challenged?” from real engine output in three languages. A conversational front end sits on top — not a rewrite.

FRI / MNRL and cybercrime reporting

Not integrated. Every BLOCK already emits a signed, structured record with customer, amount, signals and decision — the exact payload such a report needs. Connecting the feed is an integration task.

Goal-based planning and SIM-swap signals

The wealth engine already supports goals; the app does not yet send them. SIM trust is registered in the risk weights at zero weight, ready to carry signal.

We would rather name the edge of our system than demo a mock of it.